

Preparing for the DORA Oversight Framework: CTPP Designation and Next Steps

Workshop with technology service providers - 14 May 2025

Disclaimer: These slides are provided for the convenience of participants to the workshop only and aim to give high-level indications concerning the oversight framework for critical ICT-third party service providers. They do not intend to replace or provide a comprehensive overview on DORA and related delegated and implementing acts – for which you should consult the [Official Journal of the EU](#) – and do not represent any final views of the ESAs. In particular, these slides produce no legal effects and the ESAs accept no responsibility or liability whatsoever with regard to the information contained within them

How to interact with us today: rules of engagement

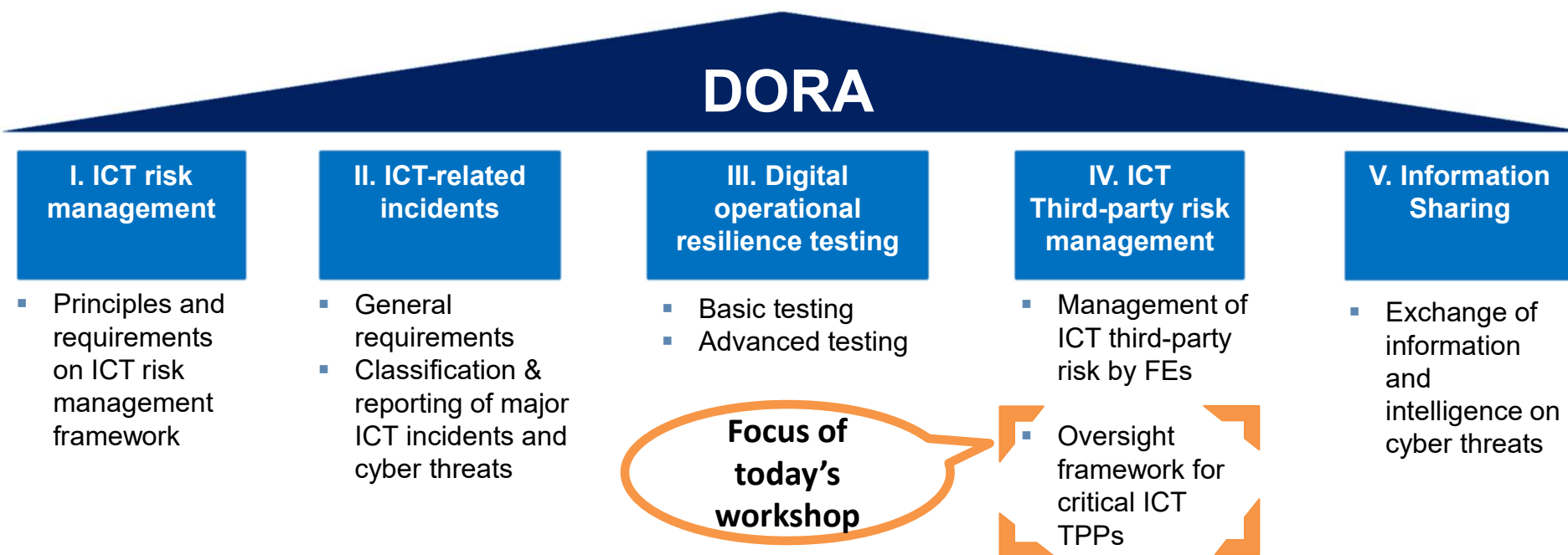
- The **workshop is organised in two parts**:
 1. A **presentation by the ESAs** providing an overview of the DORA oversight framework with a focus on the 2025 timeline and the process to designate ICT third-party service providers as critical.
 2. A **Q&A session**.
- To interact with us, **you will have the possibility to submit your inputs by using the MS Teams' Q&A extension**:
 - **All inputs are moderated.** The moderator will **not accept submissions** from individuals with **incomplete names** or **those containing offensive content**, as well as **inputs related to aspects of DORA not covered during this event**.
 - You will have the possibility to **upvote inputs submitted by other participants**.
- **The ESAs may**:
 - during the workshop, **reply to your inputs in writing** directly using the MS Teams' Q&A extension or
 - during the Q&A session, **ask the person who submitted inputs to raise his/her hand by using the “👋” button and take the floor to present his/her input**.
 - Please keep your intervention to max. 2 minutes to allow others to share their views. Always indicate your name and organisation.
 - Due to time constraints, we kindly ask for your understanding that not all contributors will have the opportunity to make an oral intervention.
 - Please refrain from raising your hand unless your name is called, as it will not be effective. Thank you for your cooperation.

Agenda

Opening speech by Petra Hielkema, chairperson EIOPA	10:00 – 10:15
Overview of the DORA oversight mandate	10:15 – 10:45
Overview of oversight activities	10:45 – 11:00
ESAs target operating model	11:00 – 11:15
Designation of critical ICT third-party service providers and first year of oversight	11:15 – 11:45
Overview of ESAs high-level expectations	11:45 – 12:00
Questions and Answers	12:00 – 13:00

The Digital Operational Resilience Act (DORA)

- [DORA](#) is applicable to all European Financial Entities from 17 Jan 2025.
- **Context:** DORA establishes a comprehensive framework for digital operational resilience for financial entities (FEs) in the EU. This is to address (i) dependency of the financial sector on technology companies and (ii) cyber risks and other vulnerabilities of FEs.
- DORA harmonises the rules concerning ICT risk management and resilience for 20+ different types of financial entities (FEs)



Rationale of the DORA oversight framework

- **Reliance on ICT third-party providers (TPPs) has been constantly rising in the financial sector, and it has become essential for the provisioning of financial services.**
 - An [ECB assessment](#) on ICT outsourcing showed an increase of 2.1% of banks ICT outsourcing budget between 2023 and 2024.
 - There is a growing trend toward the concentration of ICT services and capabilities among a limited number of TPPs, either as direct service providers or subcontractors. For example, more than 30% of the ICT budgets of significant banks are allocated to just 10 providers.
 - In case of disruption in the services posed by the most critical ICT providers, the entire financial sector may suffer crisis that could hamper public trust and generate financial stability risks.
- **DORA entrusts the three ESAs (EBA, EIOPA, ESMA) to oversee at Union level the most critical TPPs for the Financial Entities (FEs) => the CTPPs.**
 - Previous regulatory framework (i.e. pre-DORA) did not provide supervisors with adequate tools to quantify, qualify and redress the consequences of ICT risk occurring at CTPPs.

Scope of the DORA oversight mandate

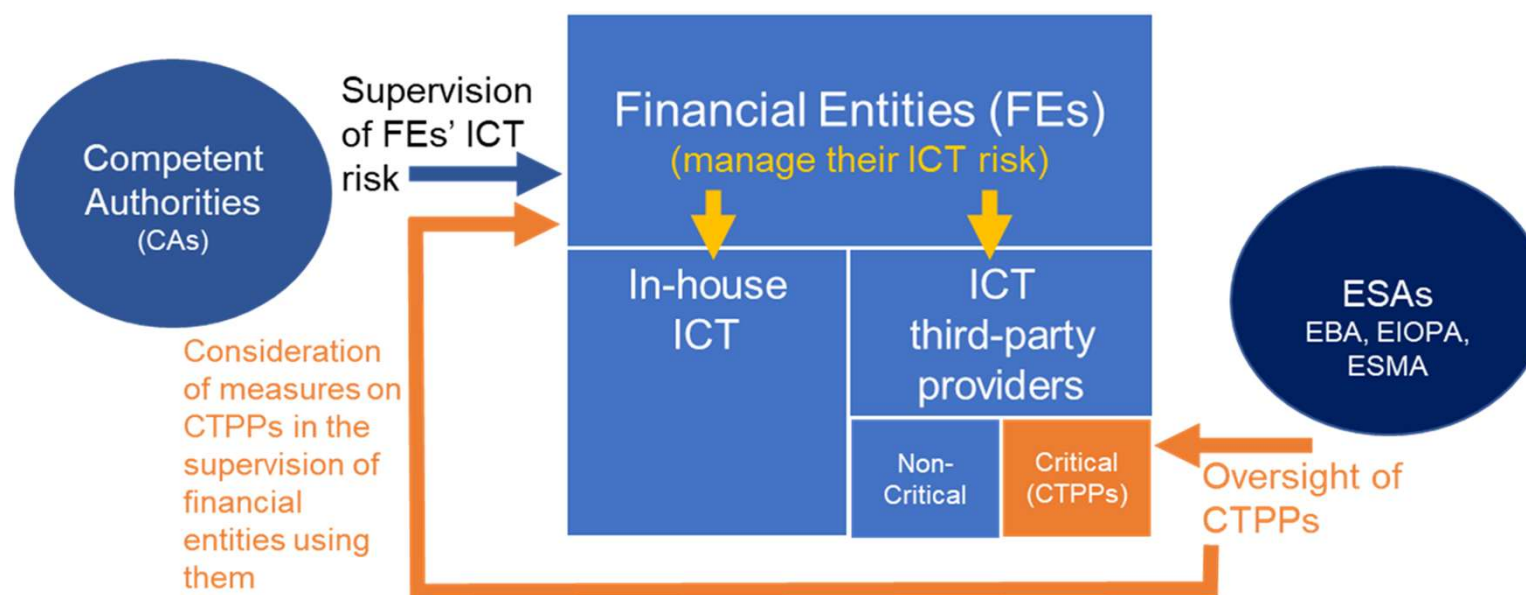
- **In scope:** Designated CTPPs providing ICT services supporting critical or important functions of European Union FEs in accordance with Article 31 of DORA and the [Commission Delegated Regulation](#) on the criticality assessment.
- **Out of scope:** ICT TPPs already subject to EU-wide oversight frameworks in relation to Article 127 TFEU tasks (e.g. SWIFT, Euroclear, TARGET2, and other systemic important payment systems); FEs providing ICT services to other FEs; ICT intra-group service providers; ICT TPPs active in one member state only.

Objectives of the DORA oversight mandate

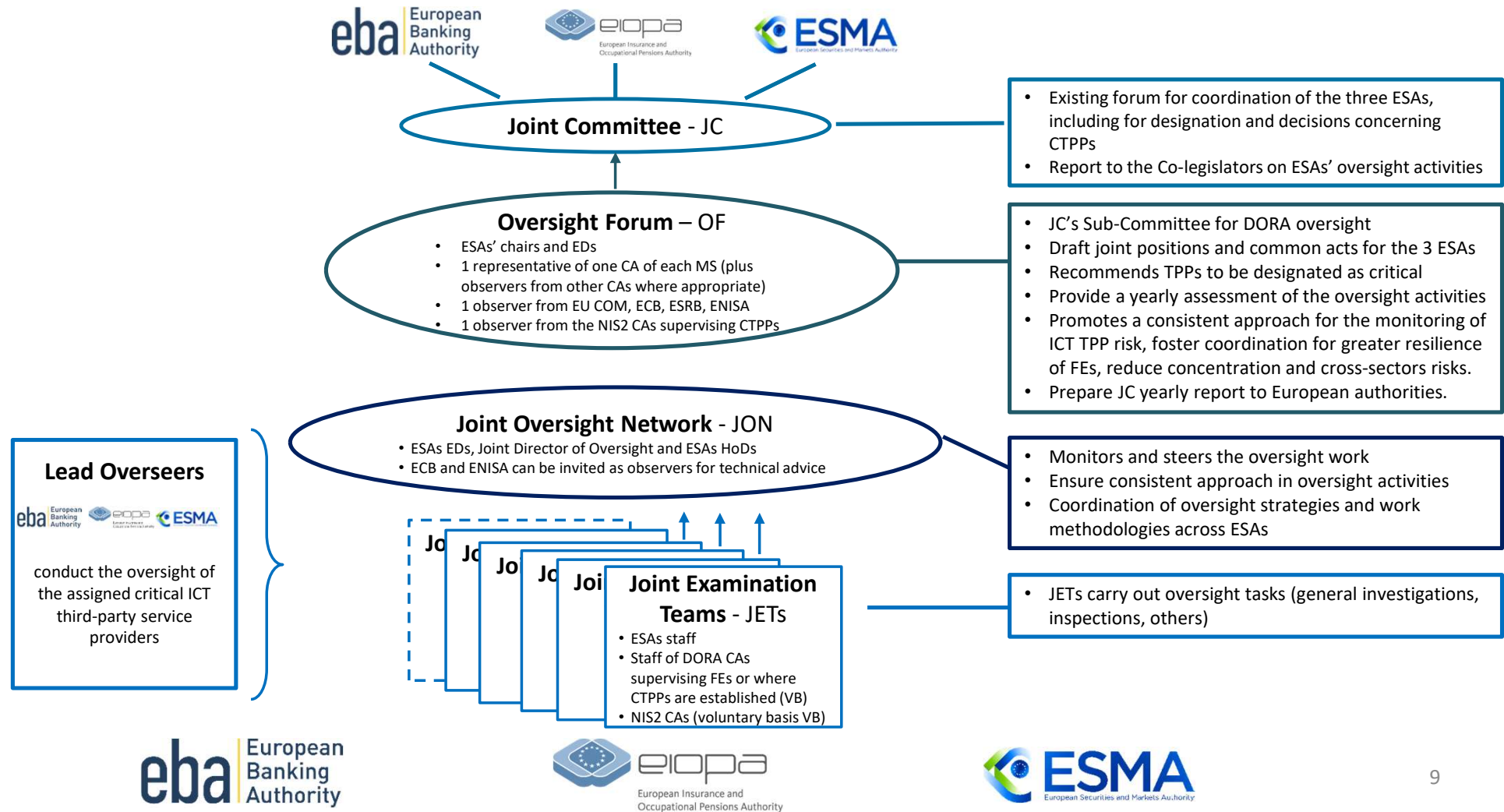
- **DORA equips the ESAs with tools to monitor the activities and the risks that CTPPs may pose to the financial sector.** To do so, the ESAs will assess whether CTPPs have in place comprehensive, sound and effective rules, procedures, mechanisms and arrangements to manage those risks.
- **The conduct of oversight activities contributes to:** (i) **promote convergence and efficiency** in relation to supervisory approaches **when addressing ICT third-party risk** in the financial sector, and (ii) **strengthen the resilience of FEs** relying on CTPPs for the provision of ICT services.
- **Oversight activities aim at preserving the Union's financial system stability and the integrity of the internal market** for financial services.
- **Operationally, the objectives of the oversight framework are to:**
 - **provide an assurance that CTPPs manage their risks** effectively while continuing to support financial entities with secure and resilient services;
 - **prevent the disruption of services**, notably through attention to dependencies, concentration and systemic risks, which could endanger the stability, continuity or quality of financial services in the EU.

The interplay between DORA oversight and the supervision of financial entities' ICT risks by competent authorities

- DORA oversight framework complements financial supervisors' (Competent Authorities – CAs) supervision of ICT risks.
- The framework is based on a cooperative model between CAs and the ESAs.



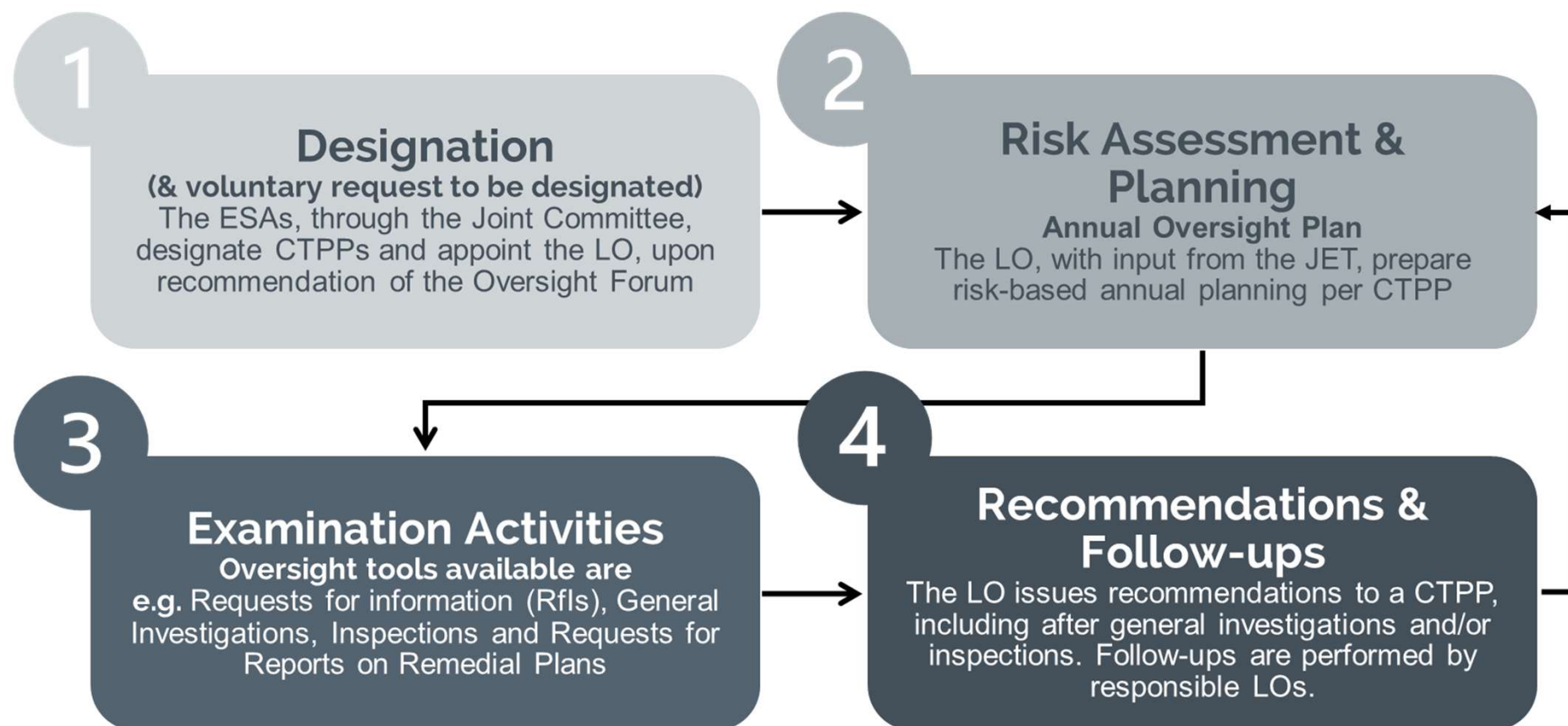
DORA oversight framework governance



Agenda

Opening speech by Petra Hielkema, chairperson EIOPA	10:00 – 10:15
Overview of the DORA oversight mandate	10:15 – 10:45
Overview of oversight activities	10:45 – 11:00
ESAs target operating model	11:00 – 11:15
Designation of critical ICT third-party service providers and first year of oversight	11:15 – 11:45
Overview of ESAs high-level expectations	11:45 – 12:00
Questions and Answers	12:00 – 13:00

DORA Oversight activities



Annual designation of CTPPs

1

Designation Process (Art. 31 of DORA, Commission Delegated Regulation (EU) 2024/1502 and RTS on oversight conduct)

1. **Data Collection for the purposes of designation**
2. **Criticality assessment**
3. **(C)TPP notification**
4. **Designation of CTPPs**
5. **Appointment of a Lead Overseer (LO)**

Possibility for other TPPs to request to be designated as critical (“opt-in”)



Annual risk assessment & planning

2

Risk Assessment

The ESAs are developing a **risk-based and proportionate Oversight Risk Assessment Process (ORAP)** to:

- Identify the CTPP risk profile based on an assessment of the CTPP-specific and transversal risks, and the controls in place;
- Determine the **oversight priorities** and the level of **oversight intensity**

Main source of information for the risk assessment are the past year's examination activities, but other sources may also be used (outcome of FEs' supervision, incident reports, information from CTPPs)

Oversight planning

On the basis of the results of the risk assessment, the ESAs will:

- Adopt a clear, detailed and reasoned **individual oversight plan** describing the annual oversight objectives/priorities, the oversight activities planned for each CTPP and the envisaged timeline.

The draft annual oversight plan is to be communicated to the CTPP.

- Prepare and update annually a **multi-annual strategic oversight plan** for all CTPPs.

Examinations and ongoing regular monitoring

3

Examinations

- Ongoing regular monitoring
 - Requests for Information (RfIs)
 - General Investigations
 - On-site Inspections and
 - Reports on Remedial Plans
- (Article 35, 37-39 of DORA and RTS on oversight conduct)

Examinations are organized in accordance with the oversight plan

The aim is to ensure that each CTPP has appropriate and effective mechanisms and procedures in place for managing the risks it poses to FEs

Examination tools – general investigations, onsite inspections, ongoing regular monitoring. These can be of different levels of intensity.

Main risk areas of focus – general risk and technology-related risks

1. Ongoing monitoring (review of periodic information, ongoing interactions, emerging issues)		
2. Requests for information (clarify a particular situation)	3. General investigations (horizontal or targeted reviews into particular risk areas)	4. On-site inspections (on-site review for further intrusiveness)
• Simple request • Request by Decision	• Thematic (horizontal) investigation • Targeted investigation • Follow-up on remediation plans	• Detailed assessment • Site review • Tests of data/solutions



Focus: Recommendations and follow up

4

Recommendations and Follow-ups

- The overseers issue recommendations linked to specific findings from the examinations.
- Follow-ups are performed by overseers and CAs.

1. Recommendations

- Based on outcome of oversight examinations (e.g. on security/quality issues, subcontracting, terms & conditions for use of ICT services)
- Communicated to the CTPP
- CTPPs expected to formally notify the overseers on their intention to follow the recommendations

2. Follow-up

- CTPP accepts or objects (with reasoning) recommendation within 60 days
- Possible public disclosure if the CTPP does not notify the LO or provides insufficient reasoning
- CAs inform FEs using the CTPP of the risks, and take supervisory actions
- ESAs may issue non-binding and non-public opinions to CAs where the CTPP refuse to endorse the recommendation and poses risks

Agenda

Opening speech by Petra Hielkema, chairperson EIOPA	10:00 – 10:15
Overview of the DORA oversight mandate	10:15 – 10:45
Overview of oversight activities	10:45 – 11:00
ESAs target operating model	11:00 – 11:15
Designation of critical ICT third-party service providers and first year of oversight	11:15 – 11:45
Overview of ESAs high-level expectations	11:45 – 12:00
Questions and Answers	12:00 – 13:00

ESAs organisation – Target Operating Model

ESAs Target Operating Model (TOM)

3 ESAs staff operate under '**one DORA Oversight team**' led by a Joint Oversight Director

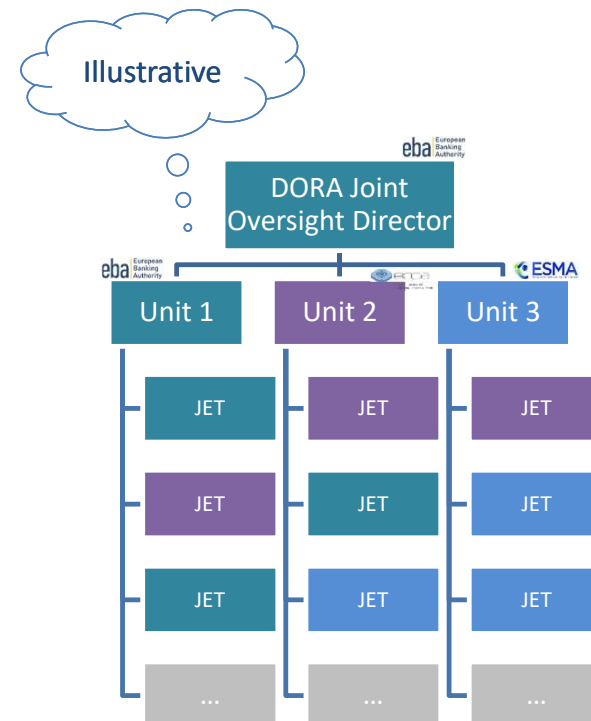
Sectorial neutral approach – same risks

Clear and stable organisation (efficiency, capacity build up, culture)

Matrix model: JETs are grouped in ESAs units, organised along the technology domains

Specialisation of JETs based on CTPPs' ICT services (e.g. cloud, hardware, consulting, data services) – relevant skills required

Partnership and strong collaboration with CAs (through JET and governance structures participation)



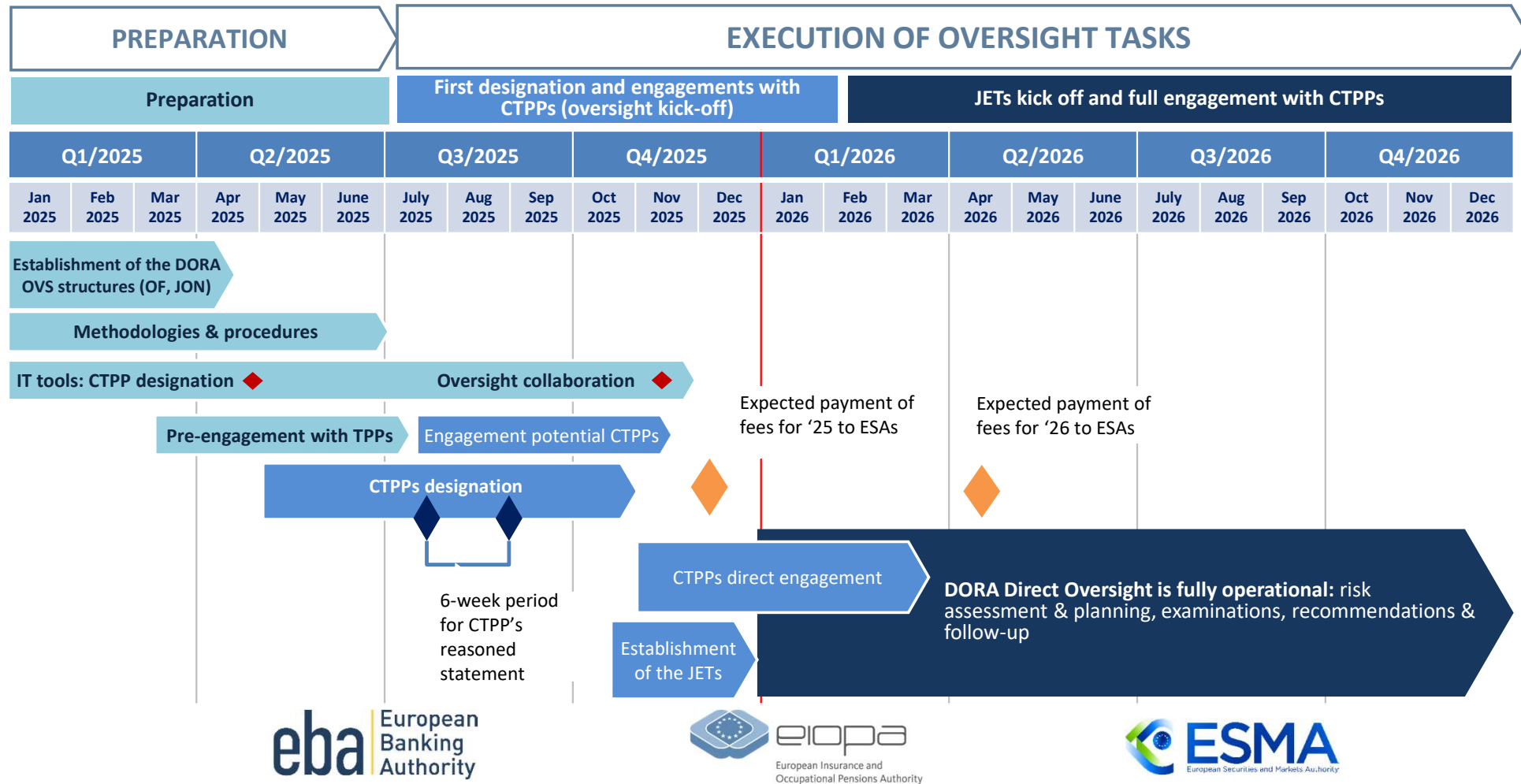
ESAs organisation – the joint examination teams

- The JETs conduct operationally all oversight tasks (off-site and on-site activities) and are the teams interacting on an ongoing basis with the CTPPs.
- The JET is established by DORA Article 40 “When conducting oversight activities [...] the LO shall be assisted by a JET established for each critical ICT third-party service provider. [...] The JET shall work under the coordination of a designated LO staff member (the ‘LO coordinator’)”
- The JET works as a single team and every staff member part of the JET works under the coordination of the ESAs.
- The JET is composed by staff members with expertise in ICT matters nominated, according to criteria concerning their skills, by the following authorities:
 - The ESAs;
 - The CAs supervising FEs making use of the ICT services provided by CTPPs;
 - On a voluntary basis, the CA where the CTPP is established;
 - On a voluntary basis, the competent authority designated or established in accordance with NIS 2 responsible for the supervision of the CTPP.

Agenda

Opening speech by Petra Hielkema, chairperson EIOPA	10:00 – 10:15
Overview of the DORA oversight mandate	10:15 – 10:45
Overview of oversight activities	10:45 – 11:00
ESAs target operating model	11:00 – 11:15
Designation of critical ICT third-party service providers and first year of oversight	11:15 – 11:45
Overview of ESAs high-level expectations	11:45 – 12:00
Questions and Answers	12:00 – 13:00

First year of the CTPPs oversight – envisaged roadmap



CTPPs designation: Process overview

CTPP designation process

1. Data Collection for the purposes of designation

- FEs submit their Register of Information (Rols) to CAs
- CAs submit the Rols to the ESAs

2. Criticality assessment

- Criticality assessment ran based on DORA and EC Delegated Regulation criteria

3. (C)TPP notification

- TPPs informed about outcome of the assessment
- 6-week period for TPPs possibility to submit a “reasoned statement”

4. Designation of CTPPs

- Assessment of information from CTPPs
- BoSs decision on designation of each CTPP (following recommendation by OF)
- Final list of CTPPs published

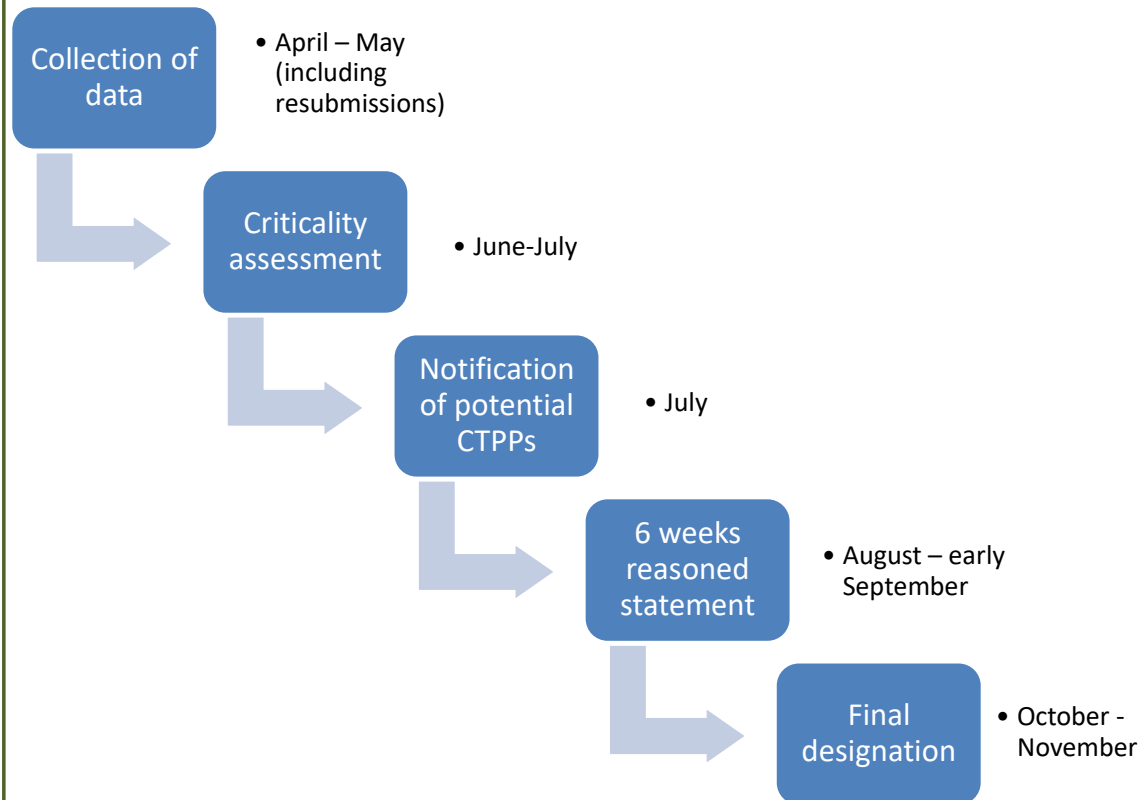
5. Appointment of a Lead Overseer (LO)

- Appointment LO – done by the BoS based on the FEs having the largest share of total assets amongst the total value of assets of all CTPP’s clients

Possibility for other TPPs to request to be designated as critical (“opt-in”)

- TPPs not designated as critical request to be designated providing the information as required in the RTS on oversight conduct.

CTPP designation milestones in 2025



CTPPs designation: Data collection and data preparation

- As part of the data collection and the data preparation, the ESAs perform the following tasks:
 - Provide data quality feedback to the submitting CAs on individual file basis → this requires interaction of the CAs with the FEs to resolve the issues
 - Process the resubmissions from the CAs of the Rols with data quality issues (several rounds are possible until the data freezing)
 - Prepare the data for the analysis, including resolving duplicate records and grouping of the ICT TPPs, where relevant, in accordance with their legal groups → According to Article 31(3) of DORA, the criticality assessment is performed at the level of the groups of ICT TPPs, where those belong to groups

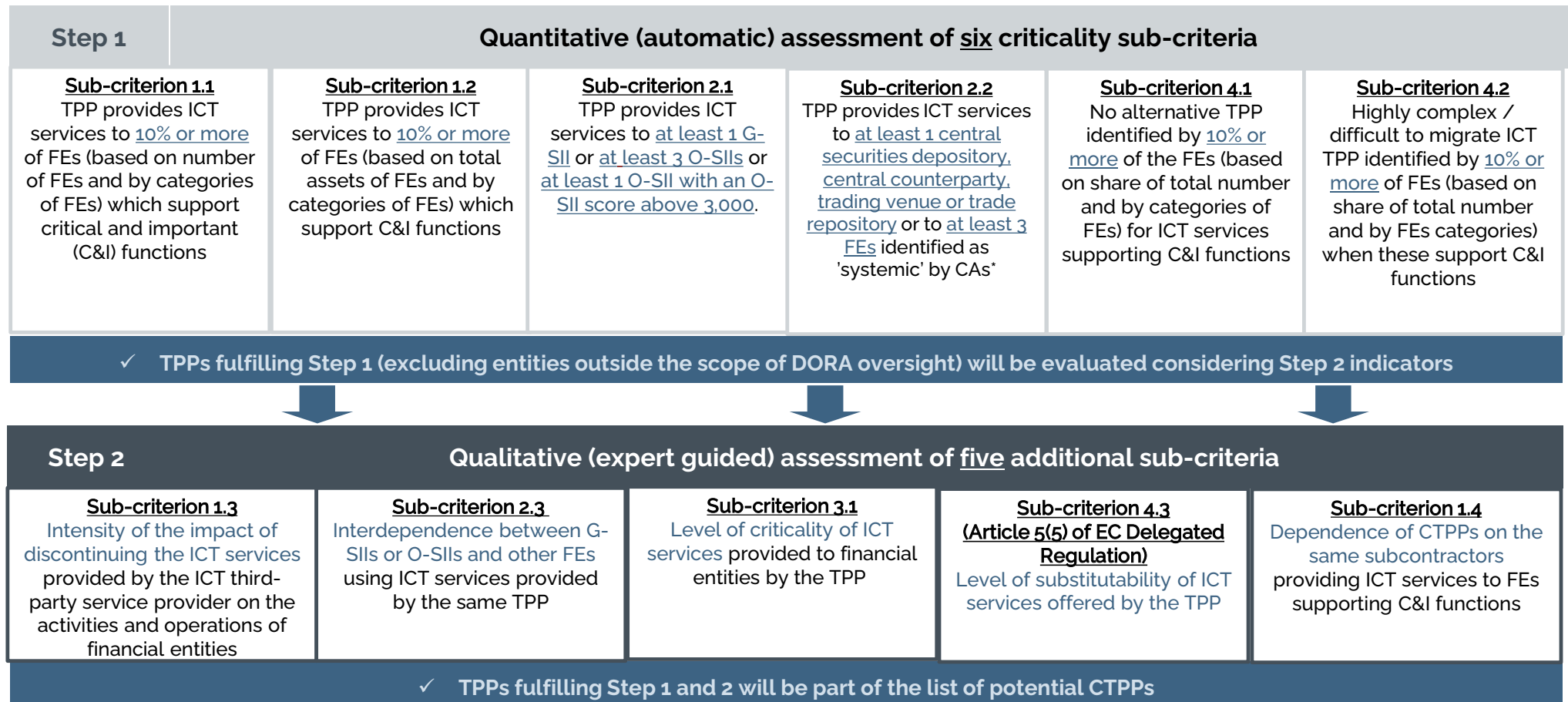
CTPPs designation: Criticality Assessment overview

According to Article 31 of DORA, **the criticality assessment is based on four broad criteria:**

- a) the **systemic impact on the stability, continuity or quality of the provision of financial services** in the event that the relevant ICT TPP would face a large-scale operational failure to provide its services;
- b) the **systemic character or importance of the FEs** that rely on the relevant ICT TPP;
- c) the **reliance of FEs on the services provided by the relevant ICT TPP** in relation to critical or important functions of FEs that ultimately involve the same ICT TPP; and
- d) the **degree of substitutability of the ICT TPP**.

The four L1 criteria are assessed using 11 sub-criteria following a two-steps process as mandated by the EC Delegated Regulation on criticality assessment. (elaborated on next slide)

CTPPs designation: criticality assessment



CTPPs designation: Reasoned statement & the ESAs decision on CTPPs designation

After the criticality assessment is completed and the ESAs have identified potential CTPPs, the following process will start:

- By **End of July 2025**, potential CTPPs will receive individual letters from the ESAs notifying about the outcome of the assessment
- From the date of notification, the ICT TPPs will have **6 weeks** where they may submit to the ESAs a reasoned statement on the assessment leading to the designation in case of object with their designation
 - The ESAs will consider the reasoned statement and may request additional information to be submitted within 30 calendar days of the receipt of such statement
- In **October-November 2025** the ESAs will prepare their decision regarding the CTPP designation and send them individually to each CTPP
- When all individual decision letters are submitted to CTPPs, the ESAs will publish the list of CTPPs on their website
- Once the list is published, the ESAs will start their interactions with the CTPPs with the first objective to develop a comprehensive understanding of the business model and the risks of the CTPPs

Oversight fees: first year (2025)

- The DORA oversight activities of the ESAs and the CAs involved are funded by CTPPs' fees (full costs).
- For the first calendar year (2025), the oversight fees will be **equally split among the CTPPs**, based on the following calculation:

$$\text{First year oversight fees} = \frac{\text{total estimated oversight costs}}{\text{number of designated CTPPs}}$$

- Then, for the following years, the oversight fees paid by the CTPPs already designated in the previous years will be calculated this way:

$$\text{Turnover coefficient in year (n)} = \frac{\text{applicable turnover of critical ICT third party service provider concerned in year (n-2)}}{\text{applicable turnover of all critical ICT third party serviceproviders in year (n-2)}}$$

- In case TPPs not included in the list of CTPPs published by the ESAs submit a request to be designated as critical (only once the list of CTPPs is published), they will be subject to a **non-refundable opt-in fee of EUR 50,000**. In case they would be designated as CTPPs at the end of the analysis (not before 2026), they would **then pay an oversight fee considering a time coefficient**.

Agenda

Opening speech by Petra Hielkema, chairperson EIOPA	10:00 – 10:15
Overview of the DORA oversight mandate	10:15 – 10:45
Overview of oversight activities	10:45 – 11:00
ESAs target operating model	11:00 – 11:15
Designation of critical ICT third-party service providers and first year of oversight	11:15 – 11:45
Overview of high-level expectations	11:45 – 12:00
Questions and Answers	12:00 – 13:00

Principles for a constructive oversight engagement

Open engagement channels



Foster constructive dialogue

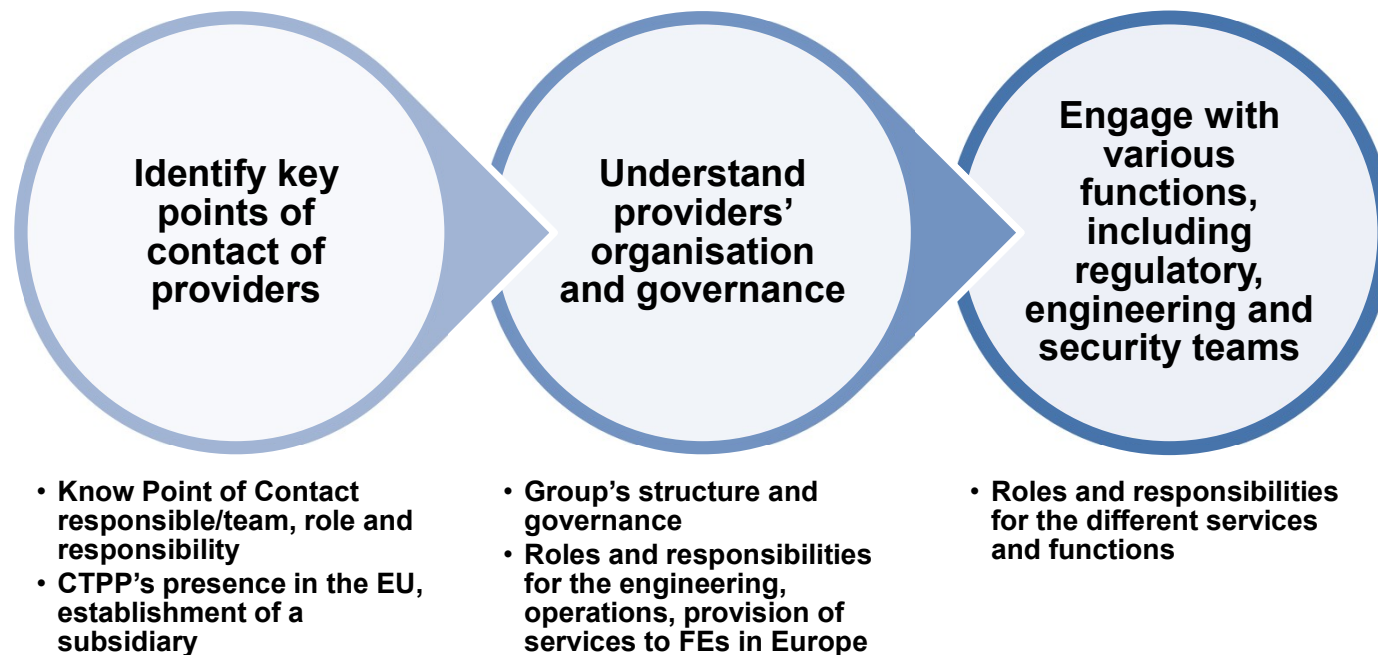


Build trust



The ESAs are committed to conduct oversight activities **transparently and constructively**, fostering **trust** among CTPPs, financial entities, Competent Authorities, and stakeholders across the EU financial ecosystem. They are taking the protection of the **security** of CTPPs data at the heart of their practice.

Initiating proactive engagement with providers



Expectations regarding the CTPPs establishment in the EU

- **Ongoing dialogue and coordination.** ESAs to establish a continuous dialogue with CTPPs, which need to be properly organised to deal with the expected multiple requests coming from the assigned joint examination teams.
- **Legal entity requirements.** DORA introduces specific requirements for EU and non-EU CTPPs regarding the establishment of legal persons and subsidiaries as contact points for the ESAs.
- **Coordination through an EU-subsidiary.** The ESAs expect that both EU and non-EU CTPPs identify an EU-subsidiary within their group to coordinate the oversight activities across the group (EU or non-EU entities). The subsidiary should have:
 - **Access to information.** The capacity to provide the ESAs with information on the services provided to EU FEs
 - **Operational and technical resources.** the authority, the technical capacity, the relevant equipment, business premises and financial resources to pull any type of relevant information and staff to address the request of the ESAs;
 - **Financial resources.** A structure to provide financial data for the calculation of the oversight fees; access to financial resources for fee payment and any applicable periodic penalty payment.
 - **Skilled and senior employees.** Enough skilled employees able to engage with the ESAs (at different level of seniority) both during examinations and in the follow up of recommendations;
 - **Empowered management.** Senior leadership with authority to commit the CTPP in relation to the oversight activities and to which escalation can be made;
 - **Onsite examination readiness.** ability to cooperate with the JETs for on-site inspection including having sufficient office spaces to welcome JET for onsite inspections.

Questions / Discussion

